

MARCO INTEGRATIVO GQM + PRAGMATIC

Trazabilidad de Objetivos Nacionales a Indicadores Técnicos del NIST AI RMF

Versión: 2.0

Fecha: Enero 2026

Clasificación: Profesional | Uso Interno

Contexto: España | Implementación EU AI Act + NIS2 + NIST AI RMF

Autores: Equipo de Gobernanza IA y Ciberseguridad

I. INTRODUCCIÓN: POR QUÉ GQM + PRAGMATIC

La gobernanza de IA en España enfrenta un desafío crítico: **alinear objetivos estratégicos nacionales (reducir riesgo regulatorio, proteger infraestructuras críticas, asegurar equidad) con indicadores técnicos concretos que el personal de TI pueda medir y actuar.**

Este alineamiento requiere dos metodologías complementarias:

1. GQM (Goal-Question-Metric): Asegura trazabilidad top-down desde objetivos conceptuales → preguntas operacionales → métricas cuantificables
2. PRAGMATIC Criteria: Asegura que cada métrica sea viable, relevante, y accionable en contexto organizacional real

Resultado: Un marco que evita tanto "métricas de vanidad" (bonitas pero inútiles) como "métricas sin propósito" (técnicamente precisas pero desconectadas de estrategia).

II. ESTRUCTURA GQM: LOS TRES NIVELES

Nivel 1: Conceptual (GOAL)

¿Qué queremos lograr estratégicamente?

Ejemplo de Goal:

GOAL: Gobernar riesgos de IA de forma que sistemas de decisión crítica (crédito, empleo, servicios públicos) sean justos, seguros y auditables en cumplimiento con EU AI Act Art. 28-99.

Object: Sistemas IA de alto riesgo en sector financiero y público

Purpose: Conformidad regulatoria + protección ciudadanos

Quality Focus: Fairness, Security, Accountability

Perspective: CISO/Compliance Officer/Regulador (AESIA)

Environment: España; transposición EU AI Act (Feb-Agosto 2026)

Nivel 2: Operacional (QUESTION)

¿Qué necesitamos saber para saber si estamos logrando el goal?

Preguntas derivadas del Goal anterior:

- Q1: ¿En qué medida los modelos de decisión están auditados para bias y fairness?
→ Perspectiva: ¿Cuál es la brecha entre auditoría requerida vs. auditoría real?
- Q2: ¿Cuál es la velocidad de detección y remediación de bias cuando se descubre?
→ Perspectiva: ¿Estamos respondiendo antes de daño material?
- Q3: ¿Cómo demostramos cumplimiento con Art. 28 (trazabilidad) ante auditoría regulatoria?
→ Perspectiva: ¿Existe documentación, logs, trail de decisiones?
- Q4: ¿Qué porcentaje de usuarios finales (ciudadanos impactados) pueden ejercer derecho a explicación?
→ Perspectiva: ¿Transparencia informada o teatro de cumplimiento?

Nivel 3: Cuantitativo (METRIC)

¿Qué datos específicos responden cada pregunta?

Para cada Question, definimos 1-3 métricas primarias:

- Q1: ¿Auditoría de bias/fairness?
- M1.1: % sistemas IA high-risk con bias audit completado
(Meta: 100% by Q2 2026; Actual baseline: 15%)
 - M1.2: Demographic parity gap en modelos auditados
(Meta: <5%; baseline: undefined, falta measurement)
 - M1.3: Audit frequency (auditorías de fairness/año)
(Meta: 2/año; baseline: 0/año)
- Q2: ¿Velocidad de remediación de bias?
- M2.1: MTTR bias incident (Mean Time To Remediate)
(Meta: <30 días; baseline: no data, ad-hoc response)
 - M2.2: % remediaciones validadas por equipo independiente
(Meta: 100%; baseline: 0%)
 - M2.3: Trend bias incidents detected → resolved (trending)
(Meta: ↓20% YoY; baseline: data unavailable)
- Q3: ¿Conformidad documentación Art. 28?
- M3.1: Audit trail completeness (% systems con logging 100%)
(Meta: 100%; baseline: 45%)
 - M3.2: Model inventory accuracy (% discrepancias en recount)
(Meta: 0% discrepancias; baseline: 15% gaps)
 - M3.3: Documentation review pass-rate (% auditable by AESIA)
(Meta: 95%+; baseline: 60%)
- Q4: ¿Transparencia/derecho a explicación operacionalizado?
- M4.1: % decisiones IA que generen explicación automática
(Meta: 95%; baseline: 10%)
 - M4.2: User satisfaction con explicación (NPS score)
(Meta: ≥6/10; baseline: 3/10)
 - M4.3: Complaint rate re: lack of explanation
(Meta: <1 per 10K decisions; baseline: 50+ per 10K)

III. CRITERIOS PRAGMATIC: VALIDACIÓN DE VIABILIDAD

Una vez definidas las métricas en GQM, evaluamos cada una contra **9 criterios PRAGMATIC**:

Definiciones de Criterios PRAGMATIC

Criterio	Definición	Aplicación
P - Predictivo	¿Indica la métrica un problema ANTES de convertirse en crisis?	Leading indicator (predice breach, fallo compliance) vs. lagging (reporta post-hecho)
R - Relevante	¿Conecta directamente a goal estratégico? Evita vanity metrics	Si métrica cae a 0%, ¿importa al negocio/reguladores?
A - Accionable	¿Puede el equipo HACER algo para mejorar el resultado?	Métrica sin control de equipo = inútil; need ownership claro
G - Genuino	¿Mide lo que DICE que mide? Evita proxies débiles	Validar que métrica no sea confusión de correlación con causalidad
S - Significativo	¿Un cambio X% en métrica produce cambio X% en outcome?	Efecto tamaño medible; no cambios de <1%
P - Preciso	¿Dato es exacto? Errores de medición <5%	Data quality, validación, no estimaciones vagas
O - Oportuno	¿Datos disponibles con frecuencia necesaria?	Daily: SIEM alerts; Weekly: pentesting bugs; Monthly: bias audits
I - Independiente	¿Equipo puede medir sin influencia política/sesgos?	Owner = equipo independiente, no development team
E - Económico	¿Cost de medir << value de insight?	ROI positivo; no gastar €50K/mes para data de €5K value

IV. MATRIZ INTEGRADA GQM + PRAGMATIC: EJEMPLO PRÁCTICO

Goal: Gobernar Fairness en Modelos IA de Decisión Crítica

GOAL (Nivel Conceptual):

"Asegurar que modelos IA de decisión crítica (crédito, empleo, servicios públicos) no discriminan por sexo, edad, origen étnico; cumplimiento EU AI Act Art. 28-99"

Environment: España; Sector: Finanzas + Administración Pública

Timeline: Q1 2026 baseline → Q2 2026 remediación → Aug 2026 compliance

QUESTION 1: ¿En qué medida están nuestros modelos de crédito auditados para detectar discriminación sistemática?

METRICS:

- M1.1: % Modelos crédito con bias audit completado
 - Baseline: 0% (nunca auditados)
 - Target: 100% (by May 2026)
 - Owner: Chief Data Officer + Ethics Officer
 - Frequency: Audit cada 6 meses post-deployment
 - Data Source: Model registry + audit checklist
- M1.2: Demographic Parity Gap (Statistical Fairness Metric)
 - Baseline: Unknown (falta medir)
 - Target: <5% difference in approval rate between groups
 - Formula: $(\text{Approval_Rate_Group_A} - \text{Approval_Rate_Group_B}) / \text{Approval_Rate_Group_B}$
 - Owner: Data Science team
 - Frequency: Quarterly (post-training)
 - Data Source: Production logs + fairness metrics platform

PRAGMATIC EVALUATION: M1.1 (% Models Audited)		
Predictivo:	✓ VERDE	Leading indicator (audit detecta bias ANTES)
Relevante:	✓ VERDE	Directo a cumplimiento EU AI Act Art. 28
Accionable:	✓ VERDE	Owner (CDO) puede contratar auditoría, asignar
Genuino:	✓ VERDE	"% auditado" = (audits completadas / total)
Significativo:	✓ VERDE	0%→100% transforma postura regulatoria
Preciso:	✓ VERDE	Data binaria (sí/no audit); error ~0%
Oportuno:	✓ AMARILLO	Quarterly es lento para emerging bias
Independiente:	✓ VERDE	Audit firm externo, no development team
Económico:	✓ VERDE	€20K audit cost / €2M+ regulatory risk mitigation
SCORE PRAGMATIC: 8/9 (VIALE CON AJUSTE)		
Ajuste recomendado: Aumentar frequency a monthly sampling (check <10% de producción para drift de bias)		

PRAGMATIC EVALUATION: M1.2 (Demographic Parity Gap %)		
Predictivo:	✓ VERDE	Detects bias WHILE en producción (real-time)
Relevante:	✓ VERDE	Métrica estándar NIST + EU AI Act
Accionable:	✓ VERDE	If gap >5%, trigger remediation playbook
Genuino:	✓ VERDE	Math formula well-defined; no ambigüedad
Significativo:	✓ VERDE	5% gap = meaningful fairness impact
Preciso:	✓ VERDE	Computed from production logs; no estimation
Oportuno:	✓ VERDE	Automated monthly + manual quarterly drill
Independiente:	✗ ROJO	Data Science team owning propia métrica
Económico:	✓ VERDE	Fairness metrics platform ~€50K/año

SCORE PRAGMATIC: 8/9 (VIABLE CON CONDICIÓN)
Condición: Audit firm revisa metodología trimestral; no auto-judgment
de acceptance criteria; external validation

V. ESTRUCTURA COMPLETA DE MAPEADO: NACIONAL → TÉCNICO

Nivel 0: Objetivo Nacional (Estratégico)

OBJETIVO ESPAÑA (SEDIA/INCIBE/AESIA):

"Implementar gobernanza IA alineada con EU AI Act; minimizar riesgo de brechas de fairness, seguridad, transparencia; liderar cumplimiento en sector público y financiero"

KPIs ALTOS NIVELES:

- Madurez NIST AI RMF promedio 3.5 (target: 3.5 by Dec 2026)
- Posición NCSI 15° → 12° (target: Q4 2026)
- Incidentes relacionados IA ↓30% YoY (baseline 2024: conocido)
- Sanciones EU AI Act: €0 (target: zero violations)

Nivel 1: Objetivo Organizacional (Gobernanza)

GOAL (CISO/Board):

"Gobernar fairness, security, accountability en sistemas IA de decisión crítica con auditoría independiente, remediación rápida, cumplimiento documentado"

Success Criteria:

- 100% sistemas críticos auditados por fairness/security/explainability
- MTTR incidents <30 días
- 0 hallazgos regulatorios pre-AESIA

Nivel 2: Objetivo Funcional (Medición)

QUESTION (CDO/Chief Architect):

"¿Están nuestros modelos de crédito/empleo/servicios públicos libres de bias sistemático detectable por auditoría externa?"

Operationalization:

- Definir demographic groups (sexo, edad, origen)
- Definir fairness metric (demographic parity, equalized odds, calibration)
- Benchmark contra dataset histórico de ground truth

Nivel 3: Objetivo Técnico (Ejecución)

METRIC (Data Science + DevOps):

- M1: % modelos con audit completado
- M2: Demographic parity gap %
- M3: Audit frequency (n/año)
- M4: MTTR fairness incident
- M5: False negative/positive rate en bias detection

Implementación:

- Script automatizado: Pull production logs
- Fairness metrics platform (Aequitas, Fairness Indicators, custom)
- Alert si gap > threshold
- Escalation a compliance/legal si > límite

VI. CASCADA GQM: GOBERNANZA → MEDICIÓN → EJECUCIÓN

NIVEL 0: OBJETIVO NACIONAL (España/AESIA)
"Liderar cumplimiento EU AI Act, fairness, seguridad"
Métrica: Madurez NIST 3.5 by Dec 2026; €0 sanciones



NIVEL 1: GOAL ORGANIZACIONAL (CISO/Board)
"Gobernar fairness en modelos IA críticos"
Desglose: Políticas + Risk Tolerance + Governance structure



NIVEL 2: QUESTIONS (CDO/Compliance)
Q1: ¿Auditoría completada? → M1: % systems audited
Q2: ¿Bias detectado? → M2: Demographic parity gap
Q3: ¿Remediación ágil? → M3: MTTR bias incident
Q4: ¿Compliance documentado? → M4: Audit trail completeness



NIVEL 3: METRICS + PRAGMATIC VALIDATION
M1: 0% → 100% (Owner: CDO; Freq: Q; Pragmatic: 8/9)
M2: Undefined → <5% gap (Owner: DS; Freq: M; Pragmatic: 8/9)
M3: ∞ → <30d (Owner: Ops; Freq: Monthly; Pragmatic: 9/9)
M4: 45% → 100% (Owner: Arch; Freq: M; Pragmatic: 9/9)



NIVEL 4: INSTRUMENTACIÓN TÉCNICA
Fairness metrics platform (Aequitas)
Automated bias detection en CI/CD
SIEM ingestion de fairness events
Dashboard para Compliance review
Playbook: Si bias > 5% gap → automatic escalation

VII. TRAZABILIDAD BIDIRECCIONAL: TOP-DOWN + BOTTOM-UP

Top-Down: Objetivo → Pregunta → Métrica → Instrumentación

¿Cómo responder: "¿Somos justos?"

↓

Pregunta operacional: "¿Qué es 'justo' en nuestro contexto?"

↓

Métrica: "Demographic parity gap <5% entre grupos demográficos"

↓

Técnica: "Calcular $(Approval_A - Approval_B) / Approval_B$ cada mes"

↓

Sistema: "Aequitas platform + alertas automáticas + manual review"

Bottom-Up: Validación de Métricas

Tenemos datos de... "Approvals por grupo demográfico"

↑

Pregunta responsable: "¿Varía tasa aprobación sistemáticamente?"

↑

Objetivo conectado: "¿Estamos violando EU AI Act fairness?"

↑

Implicación estratégica: "Riesgo regulatorio de €35M+ si gap > 10%"

↑

Acción: "Remediate o deshabilitar modelo"

VIII. MATRIZ DE ALIGNMENT: OBJETIVOS → FUNCIONES NIST → PREGUNTAS → MÉTRICAS

Objetivo	Función NIST	Question	Métrica Primaria	Pragmatic Score	Acción
Gobernar fairness	GOVERN	¿Políticas fairness?	% policies documentadas	8/9	Docum. formal, Board sign-off
Mapear impacto	MAP	¿Stakeholders impactados?	Stakeholder mapping completeness	7/9	Participatory assessment
Medir fairness	MEASURE	¿Bias en producción?	Demographic parity gap %	8/9	Automated monthly monitoring
Gestionar remediación	MANAGE	¿Remediamos rápido?	MTTR fairness incident	9/9	Escalation playbook
Auditar independencia	GOVERN	¿Testing independiente?	Audit firm sign-off rate	9/9	External validation
Asegurar transparencia	MEASURE	¿Users entienden?	Explanation satisfaction score	7/9	UX testing + feedback loops
Cumplir regulación	MANAGE	¿Audit trail?	Documentation completeness %	9/9	AESIA-ready auditing

IX. EJEMPLO INTEGRADO: OBJETIVO "REDUCIR BIAS EN HIRING AI"

Paso 1: Define Goal

GOAL: "Implementar sistema de hiring basado en IA que sea justo (no discrimina por género, edad, origen), auditable, y conforme con EU AI Act Art. 28-99 y LGPD"

Paso 2: Derive Questions

- Q1: ¿El modelo fue auditado por bias antes de deployment?
- Q2: ¿Qué tasa de discriminación potencial existe en producción?
- Q3: ¿Con qué rapidez detectamos y remediamos si encontramos bias?
- Q4: ¿Pueden candidatos recusados solicitar explicación?
- Q5: ¿Cómo probamos conformidad ante auditor regulatorio?

Paso 3: Define Metrics (GQM)

- M1: % Hiring models with pre-deployment fairness audit
Baseline: 0%; Target: 100% (by Q2 2026)
- M2: Demographic parity gap (Female approval rate vs. Male)
Baseline: Unknown; Target: <5% gap
- M3: Female false negative rate vs. Male false negative rate
Baseline: Unknown; Target: <3% difference (equalized odds)
- M4: MTTR when bias detected (Mean Time To Remediate)
Baseline: undefined; Target: <15 days
- M5: % Candidates who can obtain explanation
Baseline: 0%; Target: 100% (triggered upon rejection)
- M6: Audit trail completeness (% decisions logged with reasoning)
Baseline: 85%; Target: 100%

Paso 4: Validate with PRAGMATIC Criteria

- M1 (Audit completion):
Predictivo(✓) Relevante(✓) Accionable(✓) Genuino(✓)
Significativo(✓) Preciso(✓) Oportuno(x) Independiente(✓) Económico(✓)
Score: 8/9
Ajuste: Audit trimestral, no solo pre-deployment
- M2 (Demographic parity gap):
Predictivo(✓) Relevante(✓) Accionable(✓) Genuino(✓)
Significativo(✓) Preciso(✓) Oportuno(✓) Independiente(x) Económico(✓)
Score: 8/9
Condición: External validation de metodología fairness
- M4 (MTTR):
Predictivo(✓) Relevante(✓) Accionable(✓) Genuino(✓)
Significativo(✓) Preciso(✓) Oportuno(✓) Independiente(✓) Económico(✓)
Score: 9/9
Status: APROBADO

Paso 5: Operationalize Metrics

Implementación (Técnico):

- Data collection: Pull hiring decisions from ATS (daily)
- Fairness computation: Aequitas platform (weekly)
- Alert logic: If gap >7.5%, trigger yellow; >10% = red
- Dashboard: Visible to Hiring Manager + Compliance Officer
- Escalation: Red state → Legal review within 24h
- Remediation: Model retraining or disable model
- Evidence collection: All logs sent to SIEM for audit trail

Ownership & Accountability:

- Owner: Chief Recruiting Officer (accountability)
- Technical lead: ML Engineer (execution)
- Validator: External fairness auditor (quarterly review)
- Sponsor: General Counsel (regulatory compliance)

Cadencia de revisión:

- Daily: Automated alerting
- Weekly: Metrics check-in (Ops + ML)
- Monthly: Compliance review (Legal + Ethics)
- Quarterly: External audit + Board reporting

X. CONCLUSIÓN: DE GQM + PRAGMATIC A ACCIÓN

La síntesis de **GQM (trazabilidad) + PRAGMATIC (viabilidad)** proporciona:

3. Claridad: Cada métrica conecta explícitamente a objetivo estratégico
4. Rigor: Validación de 9 criterios asegura viabilidad operacional
5. Accountability: Owner claro, frecuencia definida, escalation path
6. Adaptabilidad: Escala de organizaciones pequeñas a grandes
7. Regulación-Ready: Documentación soporta auditoría externa (AESIA, etc.)

Resultado: Transformación de ciberseguridad y gobernanza IA de "compliance theatre" a "evidencia-driven governance."

Fin del Marco Integrativo GQM + PRAGMATIC

Documento profesional para governance de IA en España

Enero 2026 | Confidencial